

# Huellas

## Documentacion tecnica final consolidada

API y servicios, modelo de datos, seguridad, sesiones, validaciones y performance.

|                   |                                                                                 |
|-------------------|---------------------------------------------------------------------------------|
| Producto          | Aplicacion movil para adopcion de animales                                      |
| Arquitectura      | React Native + Expo   Express   Better Auth   Prisma   PostgreSQL               |
| Corte de revision | Codigo presente en el repositorio el 13/07/2026                                 |
| Alcance           | 33 operaciones HTTP expuestas por la aplicacion, datos, seguridad y rendimiento |

Dictamen: existe API REST propia. No se detectaron Firebase, Supabase ni otro BaaS de datos.

Este documento describe el comportamiento implementado, no una especificacion aspiracional. Cuando una medicion o un control no existe, se marca explicitamente como pendiente.

Entregable: doc\_tecnica\_final.pdf

# 1. Alcance y lectura ejecutiva

Se revisaron las rutas de Express, modelos Prisma, configuracion de Better Auth, middlewares, validaciones compartidas y cliente movil. La API se publica sin prefijo de version; la URL base se obtiene de EXPO\_PUBLIC\_API\_URL y por defecto apunta a `http://localhost:3000`.

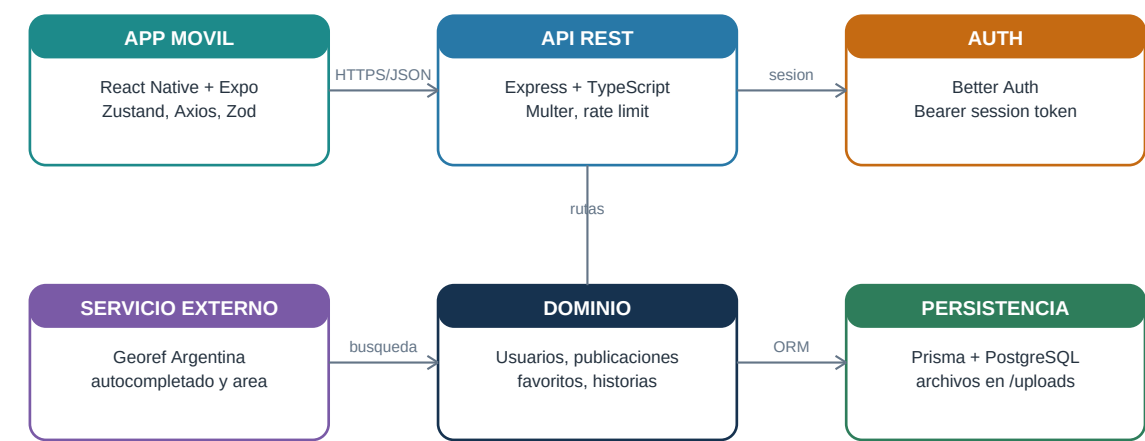
Contenido: 2) arquitectura y servicios; 3) contrato API y registro Swagger UI; 4) datos; 5) diagramas de secuencia; 6) seguridad; 7) performance; 8) plan de mejora y evidencia.

| Area                | Conclusion verificable                                                                                                                |
|---------------------|---------------------------------------------------------------------------------------------------------------------------------------|
| API                 | Express/TypeScript, Prisma y PostgreSQL. 33 operaciones de aplicacion inventariadas.                                                  |
| Autenticacion       | Better Auth con sesion persistente y plugin Bearer; no se usan JWT propios.                                                           |
| Cliente             | Expo Router, Axios, Zustand, Zod y AsyncStorage.                                                                                      |
| Riesgos principales | CORS abierto, origin check deshabilitado, limite de tasa desactivado por defecto, archivos clinicos publicos y token en AsyncStorage. |
| Metricas            | No hay instrumentacion de cold start, memoria ni bateria. No se reportan numeros no reproducibles.                                    |

**Criterio de exactitud**  
Las rutas del handler generico de Better Auth se distinguen de las rutas propias. Se documentan las operaciones de autenticacion utilizadas por el cliente y el handler `/api/auth/*`; el resto del catalogo cubre todas las rutas declaradas por esta aplicacion.

# 2. Arquitectura y servicios

El monorepo usa npm workspaces con tres paquetes: **Mobile**, **Server** y **Shared**. Shared concentra tipos TypeScript y esquemas Zod; Server es una API REST y Mobile es una app React Native administrada por Expo.



La app no usa Firebase ni otro BaaS; la persistencia es PostgreSQL administrada por Prisma.  
Las rutas de archivos se exponen mediante Express Static bajo `/uploads`; las URLs se guardan en arreglos de texto.

## Servicios y responsabilidades

| Servicio         | Responsabilidad                                                                                     | Evidencia                   |
|------------------|-----------------------------------------------------------------------------------------------------|-----------------------------|
| Mobile           | Expo Router, pantallas, estado local Zustand, Axios con interceptor Bearer y permisos de ubicacion. | Mobile/src                  |
| Server           | Rutas Express, reglas de negocio, Prisma, carga de archivos y errores HTTP.                         | Server/src                  |
| Better Auth      | Registro por email/password, sesiones almacenadas y validacion de token Bearer.                     | Server/src/config/auth.ts   |
| PostgreSQL       | Usuarios, sesiones, publicaciones, favoritos, historias clinicas y metadatos.                       | Server/prisma/schema.prisma |
| Georef Argentina | Autocompletado, normalizacion geografica y filtrado de localidad.                                   | GET /locations/autocomplete |
| Filesystem       | Imagenes y comprobantes en /uploads, publicados por Express Static.                                 | Server/uploads              |

### Integracion externa

La llamada a Georef tiene timeout de 8 s; usa `Promise.allSettled` para degradar sin impedir crear una publicacion si falla la normalizacion de area.

## 3. API REST - catalogo apto para Swagger UI

No hay paquete Swagger UI, swagger-ui-dist, swagger-ui-express ni archivo OpenAPI en el repositorio revisado. Por lo tanto no existe una interfaz Swagger UI desplegada actualmente. El siguiente catalogo es el contrato consolidado, estructurado por operaciones, que debe cargarse en una definicion OpenAPI 3.1 antes de exponerla en Swagger UI.

### Configuracion Swagger UI requerida

Servidor: `{EXP0_PUBLIC_API_URL}`. Esquema de seguridad: `bearerAuth` (HTTP Bearer). Definir respuestas comunes 400, 401, 403, 404, 409, 429 y 500. No publicar secretos ni ejemplos con tokens reales.

## Convenciones

| Tema         | Contrato                                                                                                                             |
|--------------|--------------------------------------------------------------------------------------------------------------------------------------|
| Exito        | Normalmente <code>{ success: true, data, message? }</code> ; DELETE puede responder 204 sin cuerpo.                                  |
| Error        | <code>{ success: false, message, error? }</code> . Los errores Zod incluyen errors por campo.                                        |
| Autorizacion | Bearer <code>&lt;session-token&gt;</code> en Authorization. Las rutas publicas no requieren encabezado.                              |
| Archivos     | multipart/form-data; fotos de animales y avatar: JPEG/PNG/WebP, 3 MB. Documentos clinicos: JPEG/PNG/WebP/PDF, hasta 5 MB segun ruta. |

### 3.1 Infraestructura, autenticacion y usuarios

| Metodo | Ruta                    | Acceso           | Descripcion / entrada                                                                                        |
|--------|-------------------------|------------------|--------------------------------------------------------------------------------------------------------------|
| GET    | /health                 | Publica          | Estado de la API. 200: status y timestamp.                                                                   |
| GET    | /uploads/{ruta}         | Publica          | Archivos estaticos de avatar, animal y clinica. Sin control de acceso en la ruta.                            |
| POST   | /api/auth/sign-in/email | Publica          | Better Auth. Body: email, password. Devuelve usuario y token/sesion consumidos por Mobile.                   |
| POST   | /api/auth/sign-out      | Bearer           | Better Auth. Cierra sesion servidor; Mobile limpia su almacenamiento aunque esta llamada falle.              |
| GET    | /api/auth/get-session   | Bearer           | Better Auth. Consulta/valida la sesion; el middleware interno lo invoca para proteger rutas.                 |
| POST   | /users                  | Publica          | Alta propia que delega en Better Auth. name, email, password, contact, contactType, profilePictureUrl?. 201. |
| POST   | /users/upload           | Publica          | multipart image. Carga avatar para registro; usa filtro de imagen y limite de 3 MB.                          |
| GET    | /users/{id}             | Bearer           | Perfil y publicaciones del usuario. El codigo exige sesion, pero no exige que {id} sea el solicitante.       |
| PUT    | /users/{id}             | Bearer + titular | Actualiza campos opcionales de perfil: name, email, password, contact, contactType, profilePictureUrl.       |
| DELETE | /users/{id}             | Bearer + titular | Elimina cuenta. Prisma aplica cascada a sesiones, cuentas, posts y favoritos relacionados.                   |

## 3.2 Publicaciones de animales

| Metodo | Ruta                           | Acceso           | Descripcion / entrada                                                                                                                                                                                               |
|--------|--------------------------------|------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| GET    | /animals                       | Publica          | Lista paginada. Query: q, category, size, gender, status, location, placeld, latitude, longitude, radius, minAge, maxAge, minWeight, maxWeight, userId, page=1, limit=20 (max 100).                                 |
| GET    | /animals/{id}                  | Publica          | Detalle de publicacion. 404 si no existe.                                                                                                                                                                           |
| GET    | /animals/{id}/clinical-history | Bearer           | Historia clinica de una publicacion. El comentario de ruta declara acceso a cualquier usuario autenticado.                                                                                                          |
| POST   | /animals                       | Bearer           | multipart photos[0..3] y datos: name, age, unidadTiempo, weight, size, category, gender, neutered, latitude, longitude, location; opcionales placeld, birthDate, description, status. Crea tambien ClinicalHistory. |
| PUT    | /animals/{id}                  | Bearer + titular | multipart photos[0..3], campos parciales y existingPhotosUrl serializado. Recalcula area si cambia ubicacion.                                                                                                       |
| DELETE | /animals/{id}                  | Bearer + titular | Elimina publicacion y borra del disco las fotos locales asociadas. 204.                                                                                                                                             |

## 3.3 Favoritos, busqueda y ubicaciones

| Metodo | Ruta                      | Acceso           | Descripcion / entrada                                                                                                     |
|--------|---------------------------|------------------|---------------------------------------------------------------------------------------------------------------------------|
| POST   | /favorites                | Bearer           | Body { postId }. Crea favorito para req.user.id; rechaza duplicado por indice unico postId+userId.                        |
| GET    | /favorites/check/{postId} | Bearer           | Devuelve el favorito del usuario autenticado para la publicacion o null.                                                  |
| GET    | /favorites/user/{userId}  | Bearer           | Devuelve publicaciones favoritas de userId (limite interno 100). No hay comprobacion de titularidad en la ruta.           |
| GET    | /favorites/{id}           | Bearer + titular | Obtiene favorito solo si pertenece al solicitante.                                                                        |
| DELETE | /favorites/{id}           | Bearer + titular | Elimina favorito. 204.                                                                                                    |
| GET    | /requests                 | Publica          | Busqueda avanzada de publicaciones. Usa filtros y paginacion equivalentes a animales, incluida geolocalizacion.           |
| GET    | /locations/autocomplete   | Publica          | Query input (3-200), latitude?, longitude?. Consulta Georef y devuelve hasta 8 sugerencias; limite 40/min al habilitarlo. |

## 3.4 Historia clinica y entradas

La misma instancia de rutas clinicas se monta en /animals y /clinical-histories. Eso expone alias adicionales; se listan por completitud y se recomienda consolidarlos antes de publicar Swagger UI.

| Metodo | Ruta                                                   | Acceso                | Descripcion / entrada                                                                                       |
|--------|--------------------------------------------------------|-----------------------|-------------------------------------------------------------------------------------------------------------|
| POST   | /animals/{postId}/clinical-history                     | Bearer + titular post | Alias local. multipart comprobante (0..1); type, name, date, veterinary, veterinarian, description?. 201.   |
| PUT    | /animals/{postId}/clinical-history/{itemId}            | Bearer + titular post | Alias local. Actualiza item; comprobante opcional. La ruta no usa postId en el controlador.                 |
| DELETE | /animals/{postId}/clinical-history/{itemId}            | Bearer + titular post | Alias local. Elimina item y comprobante local. 200.                                                         |
| POST   | /animals/{id}/entries                                  | Bearer + titular      | Alias de alta remota. {id} se interpreta como clinicalHistoryId, no como postId. multipart documents[0..5]. |
| POST   | /clinical-histories/{postId}/clinical-history          | Bearer + titular post | Segundo montaje del alias local; misma operacion que la primera fila.                                       |
| PUT    | /clinical-histories/{postId}/clinical-history/{itemId} | Bearer + titular post | Segundo montaje del alias local; mismo contrato.                                                            |
| DELETE | /clinical-histories/{postId}/clinical-history/{itemId} | Bearer + titular post | Segundo montaje del alias local; mismo contrato.                                                            |
| POST   | /clinical-histories/{id}/entries                       | Bearer + titular      | Alta de entrada. eventType, title (max 200), description (max 2000), date ISO, documents[0..5]. 201.        |
| PUT    | /entries/{id}                                          | Bearer + titular      | Actualiza entrada; permite existingDocumentsUrl y documents[0..5]. Borra adjuntos locales quitados. 200.    |
| DELETE | /entries/{id}                                          | Bearer + titular      | Elimina entrada y documentos locales. 204.                                                                  |

### Observacion de contrato

La operacion POST /clinical-histories/{id}/entries espera un identificador de *ClinicalHistory*. La variante montada bajo /animals/{id}/entries conserva esa semantica, aunque su URL sugiere un id de publicacion. Swagger UI debe documentar el significado correcto y no mezclar ambos recursos.

## 4. Datos almacenados y modelo de persistencia

La base usa PostgreSQL a traves de Prisma. No hay reglas de seguridad BaaS porque no se usa Firebase ni un servicio equivalente. La autorizacion se implementa en middleware y servicios de Express.

| Entidad              | Datos principales                                                                                           | Integridad / indice                                                                |
|----------------------|-------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|
| User                 | id, name, email unico, emailVerified, image, contact, contactType, profilePictureUrl, createdAt, updatedAt. | Unico email; unico compuesto contact+contactType.                                  |
| Session              | id, token unico, expiresAt, ipAddress?, userAgent?, userId.                                                 | Relacion User con cascada; indice userId.                                          |
| Account              | Proveedor, tokens OAuth?, expiraciones, scope?, password?, userId.                                          | Relacion User con cascada; indice userId.                                          |
| Verification         | identifier, value, expiresAt, timestamps.                                                                   | Soporte para flujos de verificacion de Better Auth.                                |
| Post                 | Mascota, estado, fotos, descripcion, coordenadas, placeld y area normalizada, userId.                       | Indices userId, category, size, lat/lon, localityId, municipalityId, departmentId. |
| Favorite             | postId, userId, createdAt.                                                                                  | Unico compuesto postId+userId; indices postId y userId.                            |
| ClinicalHistory      | id, postId unico, timestamps.                                                                               | Una historia por publicacion; indice postId.                                       |
| ClinicalHistoryEntry | fecha, tipo, titulo, descripcion, documentsUrl[], nombre/veterinaria/veterinario opcionales.                | Relacion con historia con cascada; indice clinicalHistoryId.                       |

### Archivos y geodatos

| Clase                         | Ubicacion                                                         | Regla implementada                                                                    |
|-------------------------------|-------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| Fotos de animales             | Servidor local /uploads/animal; URL en Post.photosUrl[].          | JPEG/PNG/WebP, hasta 3 archivos de 3 MB.                                              |
| Comprobantes clinicos locales | Servidor local /uploads/clinical-history; URL en documentsUrl[0]. | JPEG/PNG/WebP/PDF, 1 archivo de 3 MB.                                                 |
| Documentos clinicos remotos   | Servidor local /uploads/clinical; URL en documentsUrl[].          | JPEG/PNG/WebP/PDF, hasta 5 archivos de 5 MB.                                          |
| Ubicacion                     | Coordenadas en Post y coordenadas locales en AsyncStorage.        | La app solicita permiso de ubicacion; la ubicacion exacta se persiste en publicacion. |

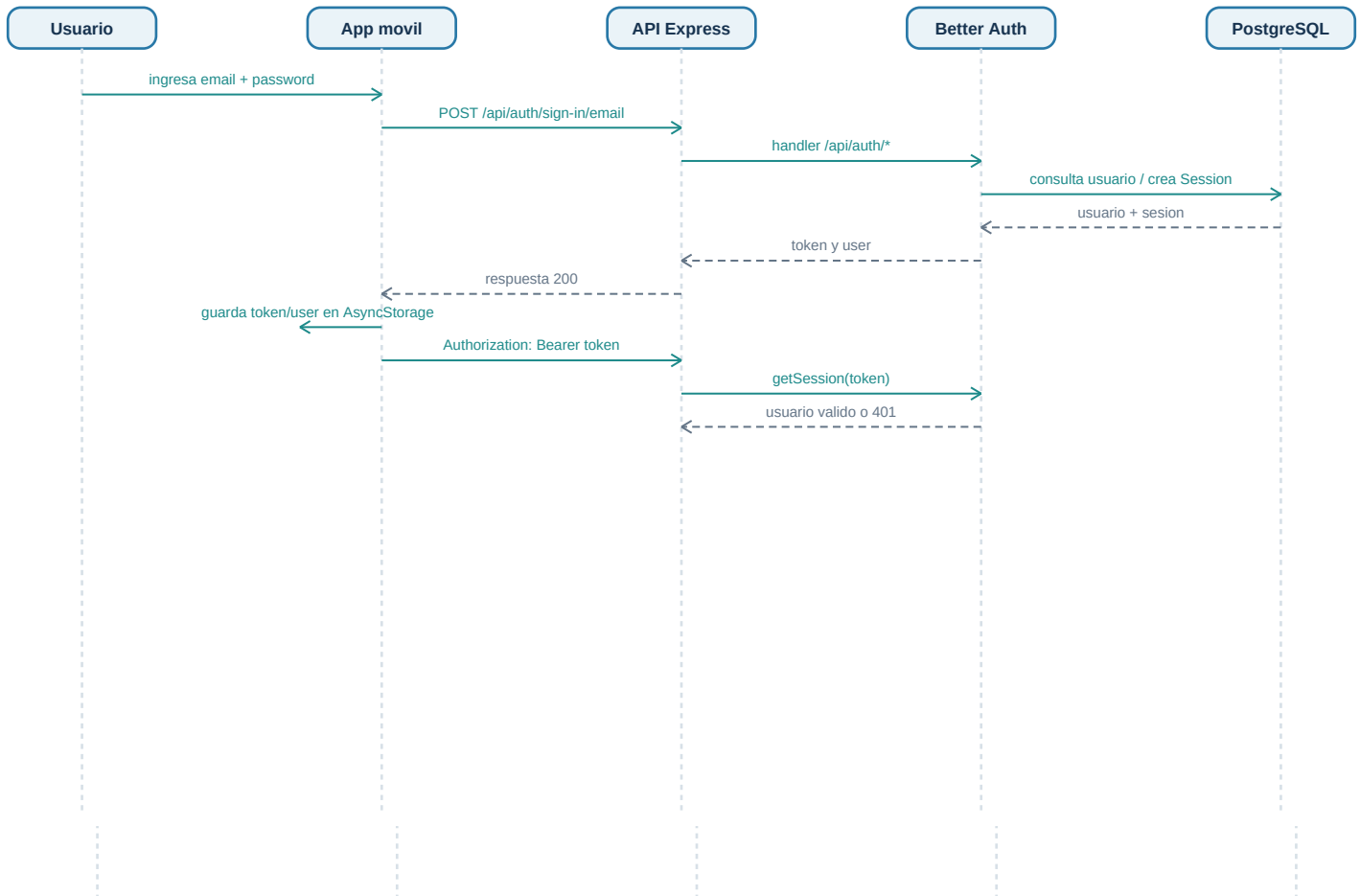
#### Retencion

No se encontro una politica de retencion, anonimato ni proceso de borrado de backups. La eliminacion de User aplica cascada de base de datos, pero la politica sobre copias de seguridad y archivos no esta definida. Debe formalizarse antes de produccion.

## 5. Diagramas de secuencia de flujos principales

### Flujo A - inicio de sesion y uso de sesion

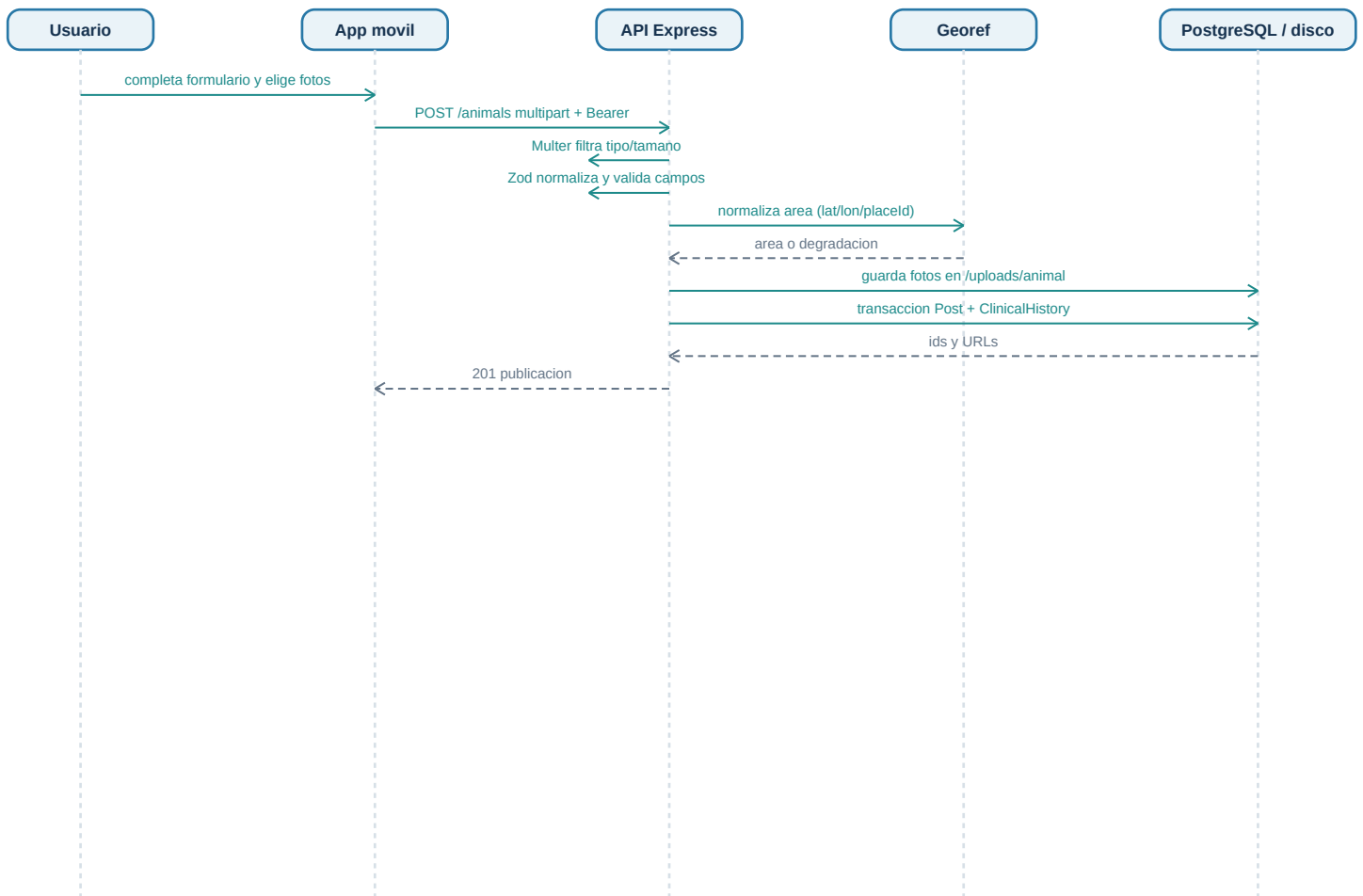
#### A. Autenticacion por email y validacion de una ruta protegida



El interceptor Axios adjunta el token en cada solicitud. Ante 401 borra token y usuario locales y desautentica el store. La sesion se conserva en la tabla Session y se valida en cada ruta protegida mediante `auth.api.getSession`.

## Flujo B - crear publicacion con fotos y normalizacion geografica

### B. Alta de publicacion y escritura transaccional



## 6. Seguridad y manejo de datos

### 6.1 Autenticacion, sesiones y tokens

| Aspecto    | Estado implementado                                                                                                                                                      |
|------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Mecanismo  | Sesion stateful de Better Auth; token opaco almacenado en Session.token. El plugin bearer permite enviarlo en Authorization.                                             |
| Expiracion | No se configura session en config/auth.ts. Better Auth v1.6.15 usa por defecto expiresIn = 7 dias (604800 s), confirmado en la dependencia instalada.                    |
| Renovacion | La dependencia tiene updateAge por defecto de 86400 s (1 dia). Al consultar sesion puede renovar la vigencia tras ese umbral; no hay refresh token propio en el cliente. |
| Validacion | requireAuth extrae solo el prefijo Bearer y consulta auth.api.getSession. Falta token, token vencido o invalido devuelven 401.                                           |
| Cliente    | AsyncStorage guarda auth_token y auth_user. initialize valida GET /users/{id}; logout llama sign-out y siempre limpia almacenamiento.                                    |
| Revocacion | Sign-out y borrado de Session por Better Auth. No hay lista de dispositivos, limite de sesiones ni revocacion administrativa configurados.                               |

## 6.2 Validaciones de entrada

| Capa          | Controles                                                                                                                                                                                                  |
|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Cliente       | Zod para login, registro y formulario de animal. Valida email, largo de contrasena, contacto por plataforma, edad/fecha, peso, ubicacion, fotos y campos de busqueda. Tambien sanitiza entradas numericas. |
| Servidor      | Shared Zod valida usuario, publicacion, query de busqueda y entradas clinicas. Convierte strings multipart a numeros y booleanos antes de validar. Errores devuelven 400 con campo.                        |
| Archivos      | Multer restringe MIME y cantidad/tamano. No inspecciona contenido binario, antivirus ni re-encode de imagenes.                                                                                             |
| Autorizacion  | Servicios comprueban titularidad para update/delete de usuario, post, favorito y registros clinicos. No todos los GET estan restringidos al titular.                                                       |
| Base de datos | Unicos e indices Prisma reducen duplicados. Las restricciones de negocio principales viven en la aplicacion, no en RLS.                                                                                    |

## 6.3 Datos personales y proteccion

| Categoria       | Datos almacenados                                                                                                                        |
|-----------------|------------------------------------------------------------------------------------------------------------------------------------------|
| Cuenta          | Nombre, email, contacto de red social/mensajeria, tipo de contacto, foto de perfil y fechas.                                             |
| Autenticacion   | Hash de password gestionado por Better Auth; token de sesion, IP y user-agent opcionales en Session; tokens de cuentas OAuth si se usan. |
| Uso de producto | Favoritos, publicaciones, fotos, descripcion y ubicacion (latitud/longitud, direccion y area normalizada).                               |
| Clinico         | Eventos veterinarios, descripcion, profesional/veterinaria y comprobantes PDF/imagen. Es categoria especialmente sensible.               |
| En dispositivo  | Token, perfil y ultima ubicacion en AsyncStorage. No se detecto almacenamiento cifrado del sistema operativo.                            |

## 6.4 Hallazgos y acciones prioritarias

| Prioridad | Hallazgo                                   | Evidencia                                                                                                        | Accion                                                                                                         |
|-----------|--------------------------------------------|------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|
| P0        | Documentos clinicos accesibles en /uploads | Express publica /uploads sin auth; las URLs de comprobantes quedan accesibles si se conocen.                     | Servir documentos clinicos mediante ruta autorizada o URL firmada con expiracion; separar bucket privado.      |
| P1        | CORS y origin check abiertos               | cors() no restringe origen y Better Auth configura disableOriginCheck: true.                                     | Lista de origins por entorno, HTTPS y origin check activo en produccion.                                       |
| P1        | Rate limit apagado por defecto             | DISABLE_RATE_LIMIT distinto de 'false' desactiva todos los limitadores.                                          | Invertir default: habilitado; definir excepcion explicita solo para test local.                                |
| P1        | Token en AsyncStorage                      | AsyncStorage no es almacenamiento seguro para credenciales de sesion.                                            | Migrar token a expo-secure-store / Keychain / Keystore y borrar datos de ubicacion al cerrar sesion si aplica. |
| P1        | Lecturas con PII no acotadas               | GET /users/{id}, GET favoritos por userId y GET historia clinica aceptan cualquier sesion segun rutas/servicios. | Aplicar ownership o campos publicos minimos; autorizar por rol y consentimiento.                               |
| P2        | Duplicacion de rutas clinicas              | Los montajes generan alias ambiguos y un path /animals/{id}/entries con semantica de ClinicalHistory.            | Consolidar recurso /clinical-histories/{clinicalHistoryId}/entries y deprecir alias.                           |

# 7. Performance, cache y optimizaciones

## 7.1 Optimizaciones comprobadas en codigo

| Tecnica     | Implementacion                                                                                                                                           |
|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Paginacion  | GET /animals y /requests usan page/limit; default 20 y maximo 100. Prisma aplica skip/take.                                                              |
| Indices     | Post tiene indices de categoria, tamano, usuario, coordenadas y area normalizada; Favorite tiene unico compuesto e indices; clinica y sesion indexan FK. |
| Consultas   | Repositorios usan select e includes acotados y ejecutan lista + count con Promise.all.                                                                   |
| UI lista    | Resultados de busqueda usan FlatList. La pantalla usa useMemo/useCallback para filtros, mapeo y carga.                                                   |
| Resiliencia | Georef utiliza timeout de 8 s y Promise.allSettled. Axios define timeout de 10 s.                                                                        |
| Transaccion | Alta de publicacion crea Post y ClinicalHistory en una transaccion Prisma.                                                                               |



## 7.2 Cache y lazy loading

| Tema             | Estado / impacto                                                                                                                                                           |
|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Cache de datos   | No se detecto cache HTTP, React Query, cache persistente de listados ni estrategia de invalidacion. AsyncStorage se usa para sesion y coordenadas, no para respuestas API. |
| Imagenes         | No se detecto prefetch, cache-control especifico ni CDN. Los archivos se sirven desde Express Static.                                                                      |
| Lazy loading     | No se detectaron imports dinamicos, React.lazy o carga diferida explicita. Expo Router organiza rutas, pero no sustituye una estrategia de carga diferida de datos.        |
| Costo geografico | El radio usa Haversine con SQL trigonometrico. El indice lat/lon existe, pero esta formula puede no aprovecharlo de forma selectiva a gran escala.                         |

## 7.3 Medicion de cold start, memoria y bateria

| Metrica           | Estado    | Razon verificable                                                                                                                             |
|-------------------|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| Cold start movil  | No medido | No hay emulador/dispositivo ni script de instrumentacion disponibles. No se inventa un tiempo de arranque.                                    |
| Memoria movil     | No medido | No hay captura de dumpsys meminfo, profiler Hermes ni escenario de carga definido.                                                            |
| Bateria           | No medido | La app usa ubicacion bajo demanda; no se detecto tracking en background. Falta prueba controlada en dispositivo fisico.                       |
| Arranque servidor | No medido | El backend compila correctamente; Docker/PostgreSQL no estaban activos durante la revision, por lo que no se pudo ejecutar health end-to-end. |

## Protocolo reproducible propuesto

- Android cold start: instalar build release, ejecutar `adb shell am force-stop com.huellas.app` y despues `adb shell am start -W -n com.huellas.app/.MainActivity`; repetir 10 veces y reportar mediana/P95 de TotalTime.
- Memoria: tras inicio, login, lista de 100 publicaciones y detalle con imagenes, capturar `adb shell dumpsys meminfo com.huellas.app`. Reportar PSS total y por escenario.
- Bateria: resetear `adb shell dumpsys batterystats --reset`, ejecutar 30 min de navegacion y 10 min de busqueda con ubicacion en un dispositivo fisico estable; reportar porcentaje, mAh si el dispositivo lo expone y wakelocks.
- Red: usar build release, API en entorno de prueba y registrar p50/p95 por endpoint, tasa de error y tamano de respuestas. No mezclar Metro ni modo desarrollo con resultados de produccion.

### Objetivos sugeridos

Acordar umbrales despues de la primera linea de base: cold start P50  $\leq$  2.5 s / P95  $\leq$  4 s en dispositivo objetivo; PSS estable sin crecimiento sostenido tras 10 ciclos; consumo de 30 min con ubicacion documentado por modelo. Son objetivos propuestos, no resultados actuales.

# 8. Plan de endurecimiento y evidencia

## Orden recomendado de implementacion

| Paso | Objetivo                   | Resultado esperado                                                                                       |
|------|----------------------------|----------------------------------------------------------------------------------------------------------|
| 1    | Cerrar exposicion de datos | Autorizar archivos clinicos, limitar perfiles/favoritos/historia clinica y definir campos publicos.      |
| 2    | Asegurar borde HTTP        | CORS allowlist, origin check activo, HTTPS obligatorio y rate limit habilitado por defecto.              |
| 3    | Fortalecer sesion movil    | Migrar a almacenamiento seguro, hacer TTL/updateAge explicitos y documentar revocacion/retencion.        |
| 4    | Normalizar API             | Crear OpenAPI 3.1, integrar Swagger UI en /api-docs y eliminar alias clinicos ambiguos con versionado.   |
| 5    | Medir antes de optimizar   | Incorporar protocolo Android y trazas API; agregar cache de lecturas e imagenes solo tras linea de base. |

Evidencia de revision

| Fuente           | Alcance comprobado                                                                                                                                    |
|------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| Rutas y servidor | Server/src/app.ts, Server/src/features/**/routes/*.routes.ts                                                                                          |
| Datos            | Server/prisma/schema.prisma y migraciones Prisma                                                                                                      |
| Auth / seguridad | Server/src/config/auth.ts; shared/middleware/authMiddleware.ts, rateLimiter.ts, uploadMiddleware.ts                                                   |
| Cliente          | Mobile/src/shared/services/api.ts, storage.ts, store/authStore.ts y esquemas Zod                                                                      |
| Build            | npm run build --workspace @huellas/server: finalizo correctamente durante la revision.                                                                |
| Limitaciones     | Sin Docker/PostgreSQL activo, sin emulador/dispositivo y sin Swagger UI/OpenAPI existente; no se ejecutaron pruebas end-to-end ni mediciones moviles. |

Cierre: el documento cubre la API REST propia, estructura de datos, dos flujos principales, seguridad, validaciones y performance. Los controles o mediciones ausentes se presentan como deuda tecnica accionable.